COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.5 · Penetration Tests

Mestre CyberSec · **Aula 5.5 — Penetration Tests** (5:29) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Pentest complementa auditoria: perspectives (external/internal/fully trusted); technique: reconnaissance, OSINT, social engineering; responsible disclosure. Mais técnica do que auditoria, menos formal.

💡 Highlights que a prova CompTIA cobra

- Pentest: EVIDENCIA exploitation real — complementa a auditoria formal
- Perspectives: external (de fora), internal (de dentro), full credencial

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'external perspective attempting to exploit from outside'=external pentest

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.5 — Penetration Tests)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Teste de Penetração (Pentest)

Tentativa autorizada e ativa de explorar vulnerabilidades reais em um sistema, fornecendo evidência do risco efetivo em vez de apenas uma lista de achados. Ele complementa uma auditoria formal ao demonstrar se uma vulnerabilidade é realmente explorável.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'active exploitation' or 'evidence of exploitability' → Pentest, NOT a vulnerability scan or audit. Pentest is more technical and less formal than a compliance audit.*

• Perspectiva Externa (N/A)

Teste de penetração realizado de fora da rede da organização, sem conhecimento interno nem credenciais, simulando um atacante anônimo na internet.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'attempting to exploit from outside the network' or 'no internal knowledge' → External perspective. Do not confuse with 'unknown environment' (which describes knowledge, not location).*

• Perspectiva Interna (N/A)

Teste de penetração conduzido de dentro da rede confiável (ou simulando um insider/funcionário malicioso) para identificar riscos que um atacante local poderia explorar.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'insider threat simulation' or 'attacker already inside the network' → Internal perspective. Remember: physical access and rogue employee scenarios map here.*

• Credencial Completa (N/A)

Escopo de penteste no qual o testador recebe credenciais válidas de usuário/admin, simulando um usuário autenticado ou insider totalmente confiável para encontrar falhas pós-autenticação.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'fully trusted' or 'provided valid login' → Full credential test. This is NOT the same as 'known environment'; credentials ≠ source code/network knowledge.*

• Reconhecimento

Etapa de coleta de informações do pentest, usada para mapear o alvo antes da exploração ativa. Inclui OSINT passivo e sondagem ativa de sistemas e serviços.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'gathering information about the target before exploitation' → Reconnaissance. Distinguish passive (no direct contact) from active (touching the target) recon.*

• Inteligência de Fontes Abertas (OSINT)

Reconhecimento passivo usando fontes publicamente disponíveis (mecanismos de busca, redes sociais, registros DNS, Shodan) para coletar informações sobre um alvo sem interagir diretamente com ele.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'publicly available sources' or 'passive information gathering' → OSINT. The key word 'passive' means no packets are sent to the target.*

• Engenharia Social (SE)

Técnica de penteste que visa o fator humano (phishing, vishing, pretexting, tailgating) para contornar controles técnicos. Frequentemente é o caminho de menor resistência para entrar em uma organização.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'exploiting people instead of systems' or 'human vulnerability' → Social engineering. Phishing/vishing/pretexting/impersonation all belong here, NOT to technical exploits.*

• Divulgação Responsável (N/A)

Processo pelo qual um pentester ou pesquisador reporta de forma privada as vulnerabilidades descobertas à organização primeiro, dando-lhe tempo para corrigir antes de qualquer divulgação pública.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'reporting vulnerabilities privately to the vendor' or 'coordinated disclosure' → Responsible disclosure. Distinguish from 'full disclosure' (public immediately) — exam questions favor responsible disclosure as the ethical choice.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de comércio eletrônico contrata uma empresa de segurança para avaliar seu aplicativo web voltado para a internet e seu gateway de e-mail. Os testadores não recebem credenciais, acesso à rede interna ou documentação, e lançam ataques a partir de sistemas hospedados na nuvem para imitar um adversário anônimo. Qual perspectiva de teste de penetração está sendo usada?

A) Perspectiva externa

B) Perspectiva interna

C) Perspectiva de credencial completa

D) Perspectiva física

QUESTÃO 2 · CENÁRIO DE EXAME

Uma instituição financeira quer saber o que um contratado mal-intencionado poderia fazer após conectar um laptop a uma porta Ethernet não utilizada em uma sala de conferências. O testador recebe um ponto de rede, mas nenhuma conta de usuário ou documentação do sistema. Qual perspectiva isso representa?

A) Perspectiva externa

B) Perspectiva interna

C) Perspectiva de credencial completa

D) Perspectiva de cadeia de suprimentos

QUESTÃO 3 · CENÁRIO DE EXAME

Durante um engajamento, o cliente fornece ao testador uma conta de usuário padrão de funcionário, um laptop corporativo e acesso normal ao prédio. O objetivo é determinar se a conta pode ser usada indevidamente para alcançar sistemas sensíveis. Qual perspectiva é esta?

A) Perspectiva externa

B) Perspectiva interna

C) Perspectiva de credencial completa

D) Reconhecimento passivo

QUESTÃO 4 · CENÁRIO DE EXAME

Antes de qualquer varredura ativa, um testador analisa registros DNS públicos, anúncios de vagas de tecnologia, estudos de caso de fornecedores e perfis de funcionários em redes sociais para identificar tecnologias e pessoal. Qual técnica está sendo usada?

A) OSINT

B) Varredura de vulnerabilidades

C) Password spraying

D) Captura de pacotes

QUESTÃO 5 · CENÁRIO DE EXAME

Um atacante liga para o service desk e afirma ser um executivo em viagem que perdeu um token de autenticação multifator. O atacante usa detalhes de um comunicado à imprensa recente da empresa para parecer convincente e pede a redefinição do token. Qual técnica de teste de penetração está ilustrada?

A) Open source intelligence

B) Engenharia social

C) Enumeração de rede

D) Exploração de vulnerabilidade

QUESTÃO 6 · CENÁRIO DE EXAME

Após um teste de penetração, o testador descobre uma falha crítica de execução remota de código no produto de um fornecedor usado por muitos clientes. O cliente confirma que não é seu código personalizado. O que o testador deve fazer em seguida?

A) Publicar o exploit em um fórum público imediatamente para forçar uma correção

B) Notificar o fornecedor privadamente e permitir um prazo razoável de correção antes da divulgação

C) Reportar apenas ao cliente e não tomar mais nenhuma ação

D) Adicionar o exploit ao relatório final do cliente, mas não contatar o fornecedor

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa concluiu uma auditoria formal de conformidade que identificou patches de segurança ausentes em servidores. O CISO quer demonstrar se um atacante poderia realmente explorar esses patches ausentes para comprometer o domínio. Qual atividade atende melhor a esse objetivo?

A) Outra auditoria de conformidade

B) Teste de penetração

C) Avaliação de risco

D) Varredura de vulnerabilidades

QUESTÃO 8 · CENÁRIO DE EXAME

Um testador é contratado para avaliar um aplicativo web. O testador primeiro consulta registros públicos WHOIS, logs de transparência de certificados e mecanismos de busca para aprender sobre a infraestrutura da organização sem enviar tráfego diretamente ao alvo. Qual fase de um teste de penetração é esta?

A) Reconhecimento

B) Exploração

C) Relatório

D) Pós-exploração

QUESTÃO 9 · CENÁRIO DE EXAME

Uma organização quer o teste mais realista de suas defesas contra um invasor que já obteve credenciais válidas de uma conta de help desk com privilégios baixos e conhece o layout da rede interna. Os testadores recebem essas credenciais, diagramas de rede e código-fonte. Qual perspectiva está sendo usada?

A) Perspectiva externa

B) Perspectiva interna

C) Perspectiva de credencial completa

D) Perspectiva de caixa-preta

QUESTÃO 10 · CENÁRIO DE EXAME

Um testador de penetração está autorizado a testar o aplicativo web público de um cliente. Durante o teste, o testador encontra uma vulnerabilidade que expõe dados de clientes. O cliente pede que o testador publique imediatamente os detalhes em uma lista de discussão pública para que outras empresas possam verificar seus sistemas. O que o testador deve recomendar?

A) Coordenar a divulgação privada com o cliente, permitir a correção e depois publicar detalhes sanitizados se apropriado

B) Publicar o exploit completo e os dados dos clientes imediatamente porque o cliente deu permissão

C) Notificar o público antes de notificar o cliente para que os usuários possam se proteger

D) Remover a descoberta do relatório e manter o exploit privado indefinidamente

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Perspectiva externa

A perspectiva externa simula um atacante fora do perímetro da organização. Os testadores começam pela internet, não têm credenciais válidas nem acesso interno e visam serviços expostos externamente. A perspectiva interna começaria dentro da rede; a credencial completa forneceria contas e documentação; a perspectiva física foca controles físicos.

Questão 2: Alternativa B — Perspectiva interna

A perspectiva interna simula um atacante ou insider que já tem acesso à rede de dentro da organização. Como o testador tem um ponto de rede, mas nenhuma conta válida ou documentação, este é um teste interno sem credenciais. A externa começaria pela internet; a credencial completa incluiria contas; cadeia de suprimentos não é uma das perspectivas padrão.

Questão 3: Alternativa C — Perspectiva de credencial completa

A perspectiva de credencial completa, também chamada de teste totalmente confiável ou com credenciais, fornece credenciais válidas e frequentemente acesso detalhado para testar abuso de privilégios de insider e movimento lateral. O teste externo começa de fora; o interno pode ter acesso à rede, mas sem credenciais; reconhecimento passivo é uma técnica, não uma perspectiva.

Questão 4: Alternativa A — OSINT

OSINT (Open Source Intelligence) é a coleta e análise de informações disponíveis publicamente. Analisar registros DNS, vagas, estudos de caso e redes sociais ajuda a criar um perfil do alvo antes do teste ativo. Varredura de vulnerabilidades, password spraying e captura de pacotes são técnicas ativas ou baseadas em tráfego.

Questão 5: Alternativa B — Engenharia social

Engenharia social manipula pessoas para contornar controles de segurança. O atacante usa uma chamada de voz e um pretexto convincente para persuadir o service desk a redefinir o MFA. OSINT pode apoiar o pretexto, mas a técnica usada para obter acesso é engenharia social. Enumeração de rede e exploração de vulnerabilidade visam sistemas, não pessoas.

Questão 6: Alternativa B — Notificar o fornecedor privadamente e permitir um prazo razoável de correção antes da divulgação

Divulgação responsável significa notificar privadamente o fornecedor afetado, dar um prazo razoável para correção e coordenar qualquer divulgação pública. Publicar imediatamente pode expor clientes; reportar apenas ao cliente pode deixar outros usuários em risco; omitir o contato com o fornecedor não resolve a falha do produto.

Questão 7: Alternativa B — Teste de penetração

Um teste de penetração é mais técnico que uma auditoria e tenta explorar fraquezas para demonstrar impacto real. Uma auditoria é mais formal e verifica conformidade; uma avaliação de risco estima probabilidade e impacto; uma varredura de vulnerabilidades identifica patches ausentes, mas geralmente não os explora.

Questão 8: Alternativa A — Reconhecimento

Reconhecimento é a fase de coleta de informações antes da exploração. Usar WHOIS, logs de transparência de certificados e mecanismos de busca sem tocar diretamente o alvo é reconhecimento passivo/OSINT. Exploração envolve ataques; relatório documenta descobertas; pós-exploração ocorre após um comprometimento.

Questão 9: Alternativa C — Perspectiva de credencial completa

A perspectiva de credencial completa fornece credenciais válidas e, frequentemente, conhecimento detalhado, como diagramas e código-fonte. Isso simula um insider confiável ou um atacante que já comprometeu uma conta. A perspectiva interna pode começar dentro da rede, mas não necessariamente inclui credenciais; a externa começa de fora; a caixa-preta fornece pouco ou nenhum conhecimento.

Questão 10: Alternativa A — Coordenar a divulgação privada com o cliente, permitir a correção e depois publicar detalhes sanitizados se apropriado

Divulgação responsável exige reportar o problema privadamente, dar tempo à parte afetada para corrigir e coordenar qualquer divulgação pública. Publicação pública imediata pode expor dados de clientes e aumentar o risco. O testador deve recomendar divulgação coordenada em vez de liberação não autorizada ou prejudicial.